

Build

Execute ZAP

Admin Configurations

Workspace: /var/lib/jenkins/workspace/zap_demo

Override Host: localhost

Default Host is : null (Configured under Manage Jenkins > Configure System)

Override Port: 8090

Default Port is : null (Configured under Manage Jenkins > Configure System)

Startup

☒ Run as Pre-Build Step

Java

Figure 5: Admin configuration section

Installation Method

☐ Custom Tools Installation

☒ System Installed: ZAP Installation Directory

Environment Variable: ZAPROXY_HOME

Run Configurations

ZAP Home Directory

Path: /var/lib/jenkins/workspace/zap_demo/ZAP

Session Management

☐ Load Session

☒ Persist Session

Figure 6: Installation method and ZAP directory

Session Properties

Context Name: default

Include in Context: https://iitfeedback.herokuapp.com/

Figure 7: Session properties

1. Install the OWASP ZAP official plugin, HTML publisher plugin and custom tools plugin. In the *Manage Jenkins* option, select *Manage Plugins*. In the available section,

select the *OWASP ZAP official plugin*, as shown in Figure 1.

2. In the *Global Tool Configuration*, click on the *custom tools installations* and complete the entries, as shown in Figure 2.

This allows us to use different tools in Jenkins like OWASP ZAP.

3. Create a new freestyle project called *ZAP_demo* using the *New Item* option shown in the dashboard (Figure 3) as soon as we start Jenkins.
4. We can start the configuration of the new project by selecting the *Configure* option when we open the project. We will get a *Configuration setup* page, as shown in Figure 4. We specify how our new project should work when we build in this page.
5. In the build stage, add a build step called *Execute ZAP* and fill in the *Admin configuration* as depicted in Figure 5.
6. If the OWASP ZAP tool is installed in the system, check the *System Installed* option in the installation method stage. If not, then check the custom tool installation option. If ZAP is already installed in the system, set the environment variable to the path of ZAP (ZAPROXY_HOME) like in Figure 6.
7. Next, in *Session management*, select *Persist session* and input any name for the session, as shown in Figure 6.
8. Under *Session properties*, set the context name to default and enter the URL where your Web application is running in the *Include in Context* option, as shown in Figure 7.
9. In the *Attack mode* stage, select the type of attack to be carried out on the mentioned Web application. This allows us to make a premeditated attack on our Web application to actively weed out the vulnerabilities from the viewpoint of the attacker. You can also choose the type of attack on the website to find different types of vulnerabilities. ZAP gives us two spiders to crawl a given Web application. These are the traditional spider and the Ajax spider. The traditional spider is faster compared to the Ajax spider but not as effective for Ajax Web